

GUÍA METODOLÓGICA: APLICACIÓN Y ANÁLISIS DE ENCUESTA INTEGRAL DE CIBERSEGURIDAD IA

España 2026 — Marco Científico y Procedimental

Versión: 1.0 Metodológica

Aplicabilidad: Gestores de proyecto, consultores seguridad, responsables gobernanza

Público objetivo: CISOs, auditors, estrategias ciberseguridad

PARTE 1: FUNDAMENTACIÓN TEÓRICA Y DISEÑO

1.1 Fundamento Conceptual de la Encuesta

La encuesta integral de ciberseguridad en sistemas IA responde a **seis ejes fundamentales** de teoría y práctica:

Eje 1: Modelos de Madurez (CMM / CMMC / NIST)

La encuesta adopta estructura **multinivel de madurez** (1-5 escala progresiva):

Nivel	Descripción	Características
1 - Inicial	No existe / Ad-hoc	Sin formalización; reactividad
2 - Básico	Iniciado / Piloto	Primeras iniciativas; cobertura <40%
3 - Intermedio	Parcialmente implementado	40-75% cobertura; formalización parcial
4 - Maduro	Implementado sistemático	>75-90% cobertura; automatización
5 - Optimizado	Continuo y adaptativo	95-100% cobertura; mejora permanente

Valor teórico: Permite tracking evolución no-lineal de postura seguridad; evita falsa dicotomía "sí/no".

Eje 2: Dominios Ciberseguridad (NIST CSF 2.0)

Encuesta cubre **4 funciones core NIST CSF 2.0**:

1. GOVERN: Gobernanza, políticas, liderazgo (Secciones II, XI)
2. MAP: Identificación activos, dependencias, riesgos (Secciones III, IV, X)
3. MEASURE: Detección, monitoreo, métricas (Secciones VI, VII)
4. MANAGE: Remediación, respuesta, mitigación (Secciones VII-IX)

Eje 3: Específico IA/ML (MITRE ATLAS)

Encuesta incluye **14 preguntas ATLAS-específicas** (Sección IX) asignadas a:

- 15 tácticas ATLAS

- 66 técnicas adversariales
- 46 sub-técnicas
- 26 mitigaciones conocidas

Novedad: Primera encuesta benchmark que integra MITRE ATLAS operacionalmente.

Eje 4: Regulatorio Europeo

Encuesta mapea conformidad con:

- **AI Act EU 2024/1689** (vigente agosto 2025)
- **NIS2 Directiva 2022/2555** (transposición 2024-2025)
- **RGPD** (Reglamento Protección Datos 2018)
- **AIDA español** (Ley Buen Uso IA, marzo 2025)

Eje 5: Métrica Cuantitativa y Cualitativa

Híbrida:

- **Cuantitativa:** MTTD, MTTC, MTTR, % clics phishing, tasa parches
- **Cualitativa:** Procesos, gobernanza, documentación, capacidad

Eje 6: Benchmarking Sectorial

Diseñada para comparabilidad:

- Segmentación por tamaño, sector, ubicación
- Análisis percentil (p25, p50, p75, p90)
- Identificación "best practice" peers

1.2 Población Target

Población 1 (Primaria): Responsables ciberseguridad España

- CISOs / Responsables seguridad (n ~2,500 estimados)
- Directores riesgos / Compliance (n ~1,500)
- CTOs / Directores TI (n ~3,000)

Población 2 (Secundaria): Auditores internos, consultores (n ~500)

Población 3 (Terciaria): Board/Gobernanza (para validación C-level) (n ~100)

Tamaño de muestra recomendado: 400-600 respondentes (error máximo $\pm 4-5\%$, confianza 95%)

1.3 Variables Principales

Variable	Tipo	Escala	Aplicación
Madurez gobernanza	Ordinal	1-5	Scoring, regresión
MTTD incidentes	Continua	horas	Media, comparativa
% clics phishing	Continua	0-100%	Percentil, clustering
Conformidad AI Act	Nominal	sí/no/parcial	Chi-square, categórica
Tamaño org.	Ordinal	Categ.	Stratificación
Sector	Nominal	Categ.	Análisis subgrupo

PARTE 2: PROTOCOLO DE APLICACIÓN

2.1 Preparación Pre-Encuesta

Fase 1: Definición Muestra (Semana 1-2)

5. Identificación población: Base datos CISOs (LinkedIn, directorios profesionales ISMSFORUM, INCIBE)
6. Estratificación:
7. Por tamaño: PYME (<250), MEDIANA (250-1000), GRANDE (>1000)
8. Por sector: Financiero, Manufactura, Telecomunicaciones, Salud, Energía, Defensa, Otro
9. Por ubicación: Autonomía en España
10. Asignación cuotas: Proporcional a distribución real (ajustar sesgo si es necesario)
11. Selección aleatoria: Random sampling dentro cada estrato

Fase 2: Contacto Inicial (Semana 1-2)

12. Correo presentación: Explicar propósito, confidencialidad, duración (~40 min), valor (benchmarking)
13. Tasa respuesta esperada: 15-25% (seguimiento necesario)
14. Incentivos (opcional): Reporte benchmark personalizado + invitación webinar resultados
15. Coordinador encuesta: Designar por región / sector para seguimiento personalizado

Fase 3: Disponibilidad Herramienta (Semana 2-3)

Opciones plataforma:

Opción	Pros	Contras
Qualtrics	Profesional, análisis integrado, RGPD-compliant	Costo alto (~€5k+)
SurveyMonkey	Fácil, asequible (~€500-1k)	Análisis limitado
LimeSurvey	Open-source, servidor propio, total privacidad	Requiere hosting técnico
Google Forms	Gratuito, rápido	No RGPD-compliant, análisis básico
Smart Survey	Balance cost-feature, RGPD, UX bueno	Medio

Recomendación: Qualtrics + protocolo RGPD formalizado (consentimiento, anonimización)

Fase 4: Consentimiento Informado RGPD (Semana 3)

Incluir:

- Propósito investigación
- Datos procesados (nivel orgánico, sector - SÍ; nombre específico empresa - NO)

- Derechos datos: acceso, rectificación, olvido
- DPO contacto
- Almacenamiento máximo 18 meses post-análisis
- Firma electrónica consentimiento

2.2 Protocolo Recolección Datos

Fase 1: Lanzamiento Encuesta (Semana 4)

16. Ventana temporal: 4 semanas (recolección activa)
17. Recordatorios:
18. +7 días: Primer recordatorio (50% tasa respuesta esperada)
19. +14 días: Segundo recordatorio
20. +21 días: Último recordatorio urgente
21. Tasa de respuesta target: 20-25% población contactada

Fase 2: Validación Respuestas en Tiempo Real

Controles calidad integrados:

Control	Regla	Acción
Consistencia lógica	Si Q4.1=5 (optimizado SIEM) pero Q4.3=1 (no UEBA), flag	Flag para revisor
Outliers	MTTD <15 min: validar credibilidad	Seguimiento/verificación
Compleitud	Secciones críticas (II, IV, VI) vacías	Recontacto obligatorio
Tiempo	Completado <5 min: probable low-effort	No descalificar; anotar sesgo

Fase 3: Seguimiento Respondentes (Semana 4-5)

22. Validación muestras borderline: Teléfono/reunión para clarificar respuestas contradictorias
23. Profundización opcional: Entrevista semi-estructurada (15 min) con subset respondentes (n~50) para triangulación cualitativa

2.3 Tasa de Respuesta y Sesgo

Tasa respuesta esperada: 20-25% (base industria encuestas B2B ciberseguridad)

Gestión sesgo:

Tipo Sesgo	Descripción	Mitigación
Non-response bias	Orgs más maduras responden más	Post-estratificar pesos; imputation
Courtesy bias	Respondentes sobreestiman madurez	Validación cruzada métricas externas (auditoría)
Selection bias	Orgs críticas ! respuesta (confidencial)	Anonimización total; confianza ISMSFORUM
Sector bias	Tech overrepresented vs. Manufacturing	Estratificación a priori

PARTE 3: ANÁLISIS DATOS

3.1 Preparación Análisis

Etapa 1: Limpieza Datos (Semana 6)

Procedimiento:

1. Eliminar respuestas completadas <5 min (n~10-20)
2. Verificar valores imposibles (e.g., MTTD=-5 horas)
3. Imputar missing valores <10% por variable (media/moda por estrato)
4. Exportar dataset limpio → CSV/SPSS/R

Etapa 2: Codificación Variables

Variable	Tipo Original	Tipo Codificado	Codificación
Madurez gobernanza	Ordinal 1-5	Numérica 1-5	Directo
Tamaño org	Nominal 7 opciones	Numérica 1-7	1=micro...7=APública
MTTD	Ordinal categorizado	Numérica	Punto medio rango (e.g., "2-8h"=5h)
Conformidad AI Act	Nominal (no/sí/parcial)	Numérica 0/0.5/1	0=no, 0.5=parcial, 1=sí
MFA implementado	Ordinal 5 opciones	Numérica 0-100%	% cobertura estimado

Etapa 3: Score Composite Madurez

Cálculo Score General Madurez (0-100):

$$\text{Score_Madurez} = [(S2 + S3 + S4 + S5 + S6 + S7 + S8 + S9 + S10 + S11 + S12 + S13) / (13 * 5)] * 100$$

Donde:

- S2-S13 = Promedio respuestas escala 1-5 por sección
- Divisor: 13 secciones × 5 puntos máximo

Resultado:

- 0-20: Muy débil (Nivel 1)
- 21-40: Débil (Nivel 2)
- 41-60: Moderado (Nivel 3)
- 61-80: Fuerte (Nivel 4)
- 81-100: Muy fuerte (Nivel 5)

3.2 Análisis Descriptivo (Estadística Básica)

A. Tendencia Central y Dispersión

Para escala ordinales 1-5:

Procedimiento SPSS/R:

- Media (M), mediana (Mdn), moda (Mo)
- Desviación estándar (σ)
- Rango intercuartil (IQR = Q3-Q1)

Interpretación:

- Si $M \approx Mdn$: distribución simétrica
- Si $M > Mdn$: sesgo positivo (orgs maduras overrep)
- Si $\sigma > 1.5$: heterogeneidad alta (practices divergentes)

Para métricas continuas (MTTD, phishing %):

Medidas estadísticas:

- Percentiles: P25, P50 (mediana), P75, P90
- Rango: Mín, Máx
- Visualización: Box plot por sector/tamaño

B. Distribuciones por Segmentación

Tabla de frecuencias estratificada:

Ejemplo - Score Madurez por Tamaño:

Tamaño	Muy DB	Débil	Moderada	Fuerte
PYME (<250)	15%	35%	35%	15%
Mediana	5%	20%	50%	25%
Grande	2%	8%	35%	55%

3.3 Análisis Comparativo (Benchmarking)

A. Posición Percentil

Para cada organización respondente:

- Calcular score madurez (0-100)
- Determinar percentil relativo cohorte:

$$\text{Percentil} = (\text{Número orgs con score} \leq \text{su_score} / \text{N total}) \times 100$$

Interpretación:

- P75: Top 25% (líderes)
- P50: Mediana (average)
- P25: Bottom 25% (necesita mejora)

B. Brecha Competitiva vs. Pares

Para organización focal vs. cohorte similar (tamaño, sector):

$$\text{Gap} = \text{Score_OrganizacionFocal} - \text{Score_Cohorte_Mediana}$$

Gap > +10: Avanzada (líder sector)

Gap -10 a +10: Aligned (comparable)

Gap < -10: Rezagada (oportunidad mejora crítica)

C. Madurez por Dominio (NIST CSF)

Cálculo independiente para cada función:

$$\text{Score_GOVERN} = [(\text{Q2.1} + \text{Q2.2} + \text{Q2.3} + \text{Q2.4}) / (4 * 5)] * 100$$

$$\text{Score_MAP} = [(\text{Q3} + \text{Q4} + \text{Q10} + \text{Q11}) / (4 * 5)] * 100$$

$$\text{Score_MEASURE} = [(\text{Q6} + \text{Q7}) / (2 * 5)] * 100$$

$$\text{Score_MANAGE} = [(\text{Q8} + \text{Q9}) / (2 * 5)] * 100$$

Resultado: Perfil radial 4 ejes (strengths/gaps identificables)

3.4 Análisis Inferencial (Estadística Avanzada)

A. Correlación entre Madurez y Métricas Incidentes

Hipótesis: Orgs con mayor madurez gobernanza – MTDD más bajo

Procedimiento:

1. Variable X: Score madurez gobernanza (1-5)
2. Variable Y: MTDD log(horas)
3. Test: Correlación Spearman ρ (variables ordinales)
4. Interpretación: $\rho > \pm 0.4$ = correlación moderada; $p < 0.05$ = significancia

B. Análisis Multivariante: Predictores de Madurez Ciberseguridad

Regresión logística multivariada:

Madurez_Ciberseguridad (1=Nivel 4-5, 0=Nivel 1-3) ~
Presupuesto + Tamaño + Sector + CISO_C_Level + Training_Horas

Resultado: Coeficientes, odds ratios, importancia predictores
Interpretación: Qué factores más fuertemente asociados a madurez

C. Diferencias Grupo (ANOVA o Kruskal-Wallis)

Test: ¿Existen diferencias significativas en score madurez entre sectores?

H0: Medias sectores = iguales
H1: Al menos un sector diferente

Procedimiento SPSS:
- Kruskal-Wallis test (ordinal data)
- Post-hoc: Mann-Whitney pairwise si H1 confirmado

Resultado: Tabla con p-values, medias sector, letras significancia

3.5 Análisis Cualitativo (Triangulación)

A. Respuestas Abiertas (Preguntas F.2, F.3)

Procedimiento:
1. Codificación temática: Asignar cada respuesta a temas predefinidos
2. Frecuencia temas: Contar menciones
3. Análisis contenido: Categorizar barreras, prioridades

Ejemplo output:
- Presupuesto insuficiente: 35% respuestas (n=140)
- Falta talento: 28% (n=112)
- Regulación unclear: 18% (n=72)

B. Entrevistas Profundidad Subset (n~50 orgs)

Protocolo:
1. Seleccionar 50 respondentes (estratificado: 25 maduros, 15 intermedios, 10 débiles)
2. Entrevista 15 min estructurada:
- ¿Cuáles mayores gaps identificados?
- ¿Barreras implementación?
- ¿Recomendaciones pares?
3. Transcribir, codificar temas
4. Integrar hallazgos cualitativos informe

PARTE 4: GENERACIÓN REPORTES

4.1 Estructura Informe Benchmark

ÍNDICE RECOMENDADO:

1. RESUMEN EJECUTIVO (2 págs)
 - Hallazgos clave
 - Posición mediana sectores
 - Recomendaciones top-3
2. METODOLOGÍA (2 págs)
 - Población, muestra (n), tasa respuesta
 - Validez, limitaciones
 - Definiciones operacionales
3. HALLAZGOS PRINCIPAL (15 págs)
 - 3.1 Score madurez general: distribución, percentiles
 - 3.2 Madurez por función NIST (GOVERN, MAP, MEASURE, MANAGE)
 - 3.3 Vulnerabilidades comunes por sector/tamaño
 - 3.4 Amenazas IA específicas (ATLAS mapping)
 - 3.5 Metrics operacionales (MTTD, clics phishing, etc.)
 - 3.6 Cumplimiento regulatorio (AI Act, NIS2, RGPD, AIDA)
4. ANÁLISIS COMPARATIVO (8 págs)
 - 4.1 Benchmarking sectorial (tabla comparativa)
 - 4.2 Benchmarking por tamaño
 - 4.3 Análisis correlación (presupuesto → madurez, etc.)
 - 4.4 Estudio de casos: "Best practice" orgs similares
5. RECOMENDACIONES ESTRATÉGICAS (4 págs)
 - 5.1 Por nivel madurez (qué hacer Nivel 2, 3, 4)
 - 5.2 Por función NIST (cómo mejorar GOVERN, etc.)
 - 5.3 IA-específicas (ATLAS mitigations)
 - 5.4 Regulatorio (roadmap AI Act, NIS2)
6. APÉNDICES
 - 6.1 Cuestionario completo
 - 6.2 Tablas estadísticas detalladas
 - 6.3 Definiciones métricas
 - 6.4 Limitaciones estudio

4.2 Personalización Reportes

Cada respondente recibe:

REPORTES PERSONALIZADO (2-3 págs):

1. Score madurez general: Tu org vs. cohorte similar
2. Heatmap 13 dimensiones (verde=fuerte, rojo=débil)
3. Gaps principales: Áreas prioritarias mejora
4. Benchmarking específico: Comparativa 10 pares similares
5. Recomendaciones personalizadas (top 5 mejoras)
6. Ruta mejora 12 meses (quick wins + largo plazo)

PARTE 5: GARANTÍAS CALIDAD Y VALIDEZ

5.1 Confiabilidad (Reliability)

A. Consistencia Interna (Cronbach's α)

Para escalas multítem (e.g., gobernanza: Q2.1-Q2.7):

- $\alpha = 0.70-0.79$: Aceptable
- $\alpha \geq 0.80$: Excelente

Procedimiento SPSS:

Analyze → Scale → Reliability Analysis

B. Test-Retest Reliability

Opcional: Re-aplicar 30 días después subset respondentes (n~50)

Correlación Pearson r respuestas:

- $r > 0.70$: Confiabilidad aceptable

5.2 Validez (Validity)

A. Validez de Contenido

Procedimiento:

1. SME Review: 5 expertos CISO/auditor revisar preguntas
2. Feedback: ¿Representan concepto? ¿Lenguaje claro? ¿Falta algo?
3. Refinamiento: Ajustar según feedback
4. Documentación: Tabla de especificaciones (construct → items)

B. Validez Constructo

Técnica: Análisis factorial exploratorio (EFA)

Hipótesis: 13 factores (secciones) = estructuras latentes

Procedimiento SPSS:

1. Analyze → Dimension Reduction → Factor
2. Método: Principal Axis Factoring
3. Rotación: Varimax
4. Extracción: Eigenvalue > 1 → factores

Resultado: Matriz cargas factoriales confirma 13 constructos

C. Validez Criterio (Predictiva)

Correlación con variable criterio externa:

- Histórico auditorías ISO 27001: Score encuesta vs. audit score
- Número incidentes reportados: Score madurez vs. volumen incidentes

Esperado: Correlación negativa moderada ($p < -0.4$)

5.3 Limitaciones Explícitas

Documentar claramente:

24. Self-report bias: Respondentes pueden overestimar/underestimar
25. Selection bias: Orgs maduras ↓ respuesta
26. Snapshot temporal: Datos específicos mes encuesta
27. Cobertura incompleta: Respuesta <25% población
28. No causalidad: Análisis correlacional, no inferir causación

PARTE 6: PROTOCOLO DISEMINACIÓN

6.1 Comunicación Resultados

Fase 1: Reporte Privado Respondentes (Mes 1 post-cierre)

- Documento personalizado + benchmarking
- Acceso webinar interpretación (opcional)

Fase 2: Informe Público Benchmark (Mes 2)

- Publicación resumen hallazgos clave
- Presentación ISMSFORUM / congresos ciberseguridad
- Acceso académico (universidades, centros investigación)

Fase 3: Sesiones Feedback (Mes 3)

- Webinar regional análisis resultados
- Discusión recomendaciones con pares

6.2 Gobernanza Datos

Almacenamiento y acceso:

- Servidor seguro RGPD-compliant (100% encriptado)
- Acceso: solo analistas project team (2-3 personas)
- Retención: 18 meses post-análisis → destrucción completa
- Anonimización: Datos publicados sin ID empresa, sector agregado

PARTE 7: CUADRO DE MANDO ANÁLISIS

7.1 Cronograma Recomendado

Fase	Duración	Responsable	Deliverable
Preparación	Semana 1-3	Project manager	Muestra finalizada, plataforma configurada
Recolección	Semana 4-7	Coordinadores encuesta	n=400-600 respuestas validadas
Análisis	Semana 8-10	Analistas data	Dataset limpio, análisis estadístico completo
Reportes	Semana 11-12	Equipo report	Reportes personalizado + benchmark público
Diseminación	Semana 13-16	Comunicaciones	Presentaciones, webinars, publicaciones

7.2 Recursos Estimados

Recurso	Cantidad	Costo Estimado
Licencia Qualtrics	1 año	5.000 €
Analistas data (2 FTE × 12 semanas)	2 personas	15.000 €
Coordinadores encuesta (1.5 FTE)	1.5 personas	7.500 €
Experto SIEM/IA (auditoría)	40h	4.000 €
Diseño reportes / comunicaciones	20h	2.000 €
TOTAL		33.500 €

PARTE 8: CASOS DE USO ANÁLISIS

8.1 Caso 1: Diagnóstico Organización Individual

Scenario: CISO grande empresa (n=850 empl) responde encuesta

Análisis personalizado:

1. Score general: 62/100 (Nivel 4)
2. Breakdown:
 - GOVERN: 75/100 (Fuerte)
 - MAP: 55/100 (Débil - vulnerabilidades no mapeadas)
 - MEASURE: 68/100 (Medio - SIEM básico)
 - MANAGE: 52/100 (Débil - incident response lento)
3. vs. Cohorte (grandes empresas sector financiero):
 - Mediana: 68/100 → Org REZAGADA (-6 puntos)
4. Recomendaciones prioritarias:
 - a) Mapeo completo vulnerabilidades (NIST Scan tools)
 - b) Mejorar MTTR (actualmente 8h → target 4h)
 - c) Red team IA (ATLAS AML.T0051 testing)

Impacto esperado: +8-10 puntos madurez en 12 meses

8.2 Caso 2: Análisis Sectorial

Scenario: Comparativa sector financiero

Hallazgo: Bancos (n=45) median 71/100; Seguros (n=28) median 64/100

Análisis:

- Gap: +7 puntos a favor bancos
- Chi-square test: $p=0.034$ (diferencia significativa)
- Causa: Bancos más inversión SIEM + PCI-DSS compliance
- Recomendación: Seguros adoptar PCI-DSS prácticas bancos

Roadmap mejora seguros:

1. Implementar SIEM (6 meses)
2. Training CISIRT (3 meses paralelo)
3. Target 12 meses: 72/100 (banco-paridad)

8.3 Caso 3: Identificación Best Practice

Scenario: Identificar "pequeña empresa líder" (10-49 empl) en PYME

Hallazgo: n=1 pequeña empresa con score 78/100 (top 90 percentil)

Análisis:

- Fortalezas: GOVERN (80), MFA (100%), training (mejorado 40% clics → 8%)
- Práctica replicable: Training gamificado mensual bajo costo
- Debilidad: SIEM limitado (pero compensado con EDR + comportamiento)

Documento case study:

- "PYME Segura: Cómo pequeña empresa logró madurez sin megapresupuesto"
- Aplicable a +500 PYMES similares

ROI estimado para sector PYME si adopta: +€2M ahorrados incidentes evitados

PARTE 9: ITERACIÓN Y MEJORA CONTINUA

9.1 Ciclo Anual

AÑO 1 (2026):

- Encuesta piloto (n=200) → refinamiento preguntas
- Análisis inicial

AÑOS 2-3 (2027-2028):

- Encuestas anuales (n=400-600)
- Tracking evolución tendencias
- Actualización preguntas según ATLAS updates, nuevas regulaciones
- Benchmark histórico: "¿Ha mejorado España sector?"

AÑO 4+ (2029+):

- Encuesta bianual
- Análisis longitudinal (panel seguimiento)
- Índice madurez ciberseguridad España (similar ENISA Index)

9.2 Actualización Contenido

Revisión	Trigger	Cambios
Trimestral	ATLAS updates, CVE críticas	Preguntas ATLAS nuevas técnicas
Semestral	Regulación nueva (AIDA, etc.)	Preguntas cumplimiento
Anual	Tendencias industria, feedback	Refinamiento opciones respuesta

FIN GUÍA METODOLÓGICA

ANEXOS

Anexo A: Definiciones Operacionales Métricas Clave

MTTD (Mean Time To Detect): Promedio horas desde ocurrencia incidente hasta detección sistema seguridad

MTTC (Mean Time To Contain): Promedio horas desde detección hasta aislamiento amenaza

MTTR (Mean Time To Recover): Promedio horas desde contención hasta restauración operacional

Tasa clics phishing: % de emails phishing simulado en los que empleado hizo clic/descargó adjunto

Conformidad AI Act: Autoevaluación % requerimientos EU 2024/1689 implementados

Documento preparado por: Consorcio Análisis Datos & Estrategia Ciberseguridad

Aprobado: Enero 2026

Clasificación: Público (metodología; datos anónimos)